

NIST AI RMF

Artificial Intelligence Risk Management Framework
NIST AI 100-1 | Published January 2023

Portfolio Project | Applied to NexaHealth AI Diagnostic Platform | 2024

Prepared By	Organization	Framework	Date
Cybersecurity Analyst	NexaHealth Inc.	NIST AI RMF 1.0	2024

1. Executive Summary

This document presents a complete NIST AI Risk Management Framework (AI RMF) portfolio project for NexaHealth Inc.. This healthcare technology company has developed an AI-powered diagnostic tool designed to assist physicians in identifying early-stage diseases from medical imaging. This project demonstrates the full AI RMF lifecycle, including understanding AI risk and applying the four core functions. GOVERN, MAP, MEASURE, and MANAGE.

The NIST AI RMF, published by the National Institute of Standards and Technology in January 2023, is the most recognized AI risk-management standard in the United States. It is rapidly becoming a requirement for organizations deploying AI systems, especially in high-risk sectors such as healthcare, finance, criminal justice, and national security.

Item	Detail
Organization	NexaHealth Inc.
Industry	Healthcare Technology / Medical AI
AI System	NexaDiag – AI-powered medical imaging diagnostic tool
AI Use Case	Assist the radiologist in detecting early-stage lung cancer from CT scans

Risk Level	HIGH – AI decisions directly impact patient health outcomes
Framework	NIST AI RISK Management Framework (AI RMF 1.0) –NIST AI 100-1
Core Functions	GOVERN, MAP, MEASURE, MANAGE
Project Status	AI RMF Fully Applied — Risk Profile Documented

2. What is the NIST AI RMF?

2.1 Plan English Explanation

The NIST AI RMF is a framework that helps organizations identify and manage risks that arise specifically from the use of Artificial Intelligence systems. Traditional cybersecurity frameworks such as NIST CSF and ISO 27001 focus on risks such as hacking, ransomware, and data breaches. AI introduces entirely new categories of risk that these frameworks do not address.

Examples include:

- What if an AI makes an incorrect medical diagnosis?
- What if an AI model used to approve loans is racially biased?
- What if an AI chatbot gives dangerous medical advice?
- What if an AI system produces harmful or misleading content?

These are AI-specific risks, and the AI RMF provides structured methods to manage them.

2.2 Why AI Risk is Different from Regular Cybersecurity Risk

Risk Type	Traditional Cyber Security	AI-Specific Risk
Accuracy	The system either works or it doesn't	AI can be confidently WRONG — and look correct
Bias	Not a concern for firewalls or antivirus	AI can discriminate based on race, gender, and age
Explainability	Code does what it's programmed to do	AI decisions may be impossible to explain (black box)
Drif	Software doesn't change on its own	AI performance degrades over time as data changes

Data Provisioning	Hackers breach the system	Hackers corrupt the training data to manipulate AI
Misuse	Unauthorized access to the system	AI can be used for deepfakes, disinformation, and fraud

2.3 The 4 Core Functions of the AI RMF

The AI RMF is organized around four core functions. Think of these as the four things every organization must do when they use AI. They are conceptually similar to the five functions in the NIST CSF (Identify, Protect, Detect, Respond, Recover) but are designed specifically for AI systems.

Function	Name	Plain English — What You Do
GOVERN	GOVERN	Set up the rules, policies, roles, and culture your organization needs BEFORE you deploy any AI. Who is responsible if the AI causes harm? What is your AI use policy?
MAP	MAP	Identify and categorize all AR risks for your specific system. What could go wrong? Who could be harmed? How serious is each risk? Map it out before you build.
MEASURE	MEASURE	Qualify and test those risks using metric evaluation and audits. How biased is AI? How accurate? How often does it fail? Put real numbers on the risks.
MANAGE	MANAGE	Treat the risk you found. Implement controls, set priorities, monitor ongoing performance, and respond if something goes wrong with the AI system.

3. Project Scenario — NexaHealth AI Diagnostics

You are an AI risk-management analyst hired by NexaHealth Inc. The company has developed NexaDiag, an AI system that analyzes CT scans to flag potential early-stage lung cancer for

radiologist review. The model was trained on 500,000 historical CT scans and is being evaluated for deployment across 12 hospitals in the Southeastern United States.

Before deployment, hospital administrators and legal counsel require a full AI RMF assessment to determine whether NexaDiag is safe, trustworthy, and ready for clinical use.

System Detail	Nexa Diag Specifications
AI System	NexaDiag v2.1
AI Type	Deep learning convolutional neural neutral cnn
Training Data	500,000 CT scan images from eight hospital systems (2015- 2023)
Purpose	Flag potential lung cancer findings for radiologists' review, not to replace radiologist judgment
End users	Radiologist and oncologist at 12 Partner Hospitals
Decision Impact	Highly incorrect output could delay cancer diagnosis or trigger unnecessary procedures
Regulatory Context	FDA class II medical device software, SaMD (software as a medical device)
Affected Populations	Patients ages 40-80, with higher prevalence and lower income, and minority communities

4. GOVERN — AI Governance Structure

The GOVERN function establishes the policies, roles, and organizational expectations required to manage AI risk. It answers: Who is accountable? What rules govern AI use? What oversight is required?

4.1 AI Governance Roles & Responsibilities

Role	Person/ Team	Responsibilities
Chief AI Officer	Jessica Willis	Final accountability for all AI systems; Approves deployment decisions; Reports to the board
AI Risk Manager	Cybersecurity Team	Conduct AI RMF assessments, maintain a risk register; monitors ongoing performance
Clinical AI Oversight	Medical Advisory Board	Review clinical accuracy; approved AI use and patient care; evaluation bias impacts
Data Governance Lead	Data Engineering Team	It sure is training data quality, diversity, and compliance with HIPAA and FDA requirements
AI Ethics Committee	Cross-Functional Team	Review AI decisions for fairness, bias, and ethical concerns; meeting quarterly
Legal & Compliance	General Counsel	Ensures FDA SaMD compliance, manages liability, and reviews AI-related patient consent forms

4.2 AI Use Policy — Key Requirements

- NexaDiag is a decision-support tool; radiologists must confirm all findings.
- AI outputs must not be delivered directly to patients without physician review.
- All AI-assisted diagnoses must be documented within the patient record.
- NexaDiag must be retrained or suspended if accuracy falls below 92% on validation datasets.
- Any AI-related incident causing patient harm must be reported to the FDA within 30 days.
- Annual third-party bias audits are required for license renewal at each hospital.

5. MAP — AL RISK Identification

The MAP function identifies and categorizes risks across accuracy, bias, reliability, explainability, and patient safety.

5.1 AI Risk Register — NexaDiag

AI Risk	Risk Category	Likelihood	Severity	Potential Harm
False Negative/ AI misses cancer	Accuracy	MEDIUM	CRITICAL	Patient's cancer goes undetected; Delayed treatment; Patient death
False Positive / AI flags a healthy issue	Accuracy	MEDIUM	HIGH	Unnecessary biopsies, patient anxiety, increase healthcare costs
Demographic bias/ lower accuracy for minorities	Fairness/Bias	HIGH	CRITICAL	AI trained on non-diverse data platforms works for black and Hispanic patients
Model drift/ accuracy degrades over time	Reliability	HIGH	HIGH	As CT scan technology evolves, AI trained on old data becomes less accurate
Data poisoning attack	Security	LOW	CRITICAL	Attacker corrupts training data to cause systematic misdiagnosis
Black box decisions/ no Explanation	Explainability	HIGH	MEDIUM	A radiologist cannot understand WHY I flag a scan; reduce trust and oversight.
Over-reliance by clinicians	Human Oversight	MEDIUM	HIGH	Radiologists stop revealing critical AI outputs, miss AI errors
Adversarial attack on input images	Security	LOW	HIGH	Attackers manipulate CT scan pixels to fool AI into wrong classification

5.2 Trustworthy AI Characteristics — NIST Assessment

NIST Defines 7 characteristics that trustworthy AI systems must demonstrate. NexaDiag is assessed against each of the following:

Characteristics	Status	NexaDiag Assessment
Accurate	PARTIAL	94.2% overall accuracy but only 89.1% for black patients. The bias gap must be closed before deployment
Explainable	PARTIAL	Grad-CAM if its realization shows which image regions influence the decision, but a clinical explanation is not yet possible.
Interpretable	PARTIAL	Radiologists can see a confidence score (0-100%) but cannot fully interpret the model's reasoning chain.
Privacy-Enhanced	PASS	All training data is de-identified in accordance with HIPAA. Differential privacy techniques apply during model training
Reliable	PASS	99.2% uptime. performance tested across 6 CT scan models and three different image resolutions.
Safe	PARTIAL	The false negative rate (3.1%) exceeds the acceptable clinical threshold of 2.0% and requires model improvement before deployment.
Fair/Unbiased	FAIL	Statistically significant accuracy gap of 50.1% between White and Black patient populations. DEPLOYMENT BLOCKED until resolved.

6. MEASURE — AI RISK QUALIFICATIONS

The MEASURE function puts real numbers on AI risks. It is not enough to say "there might be bias"; you must measure HOW MUCH bias. HOW OFTEN The AI fails, and WHAT THE IMPACT is. This section documents the metrics, testing results, and evaluation methods used to qualify NexaDiag's risks.

6.1 Performance Metrics — NexaDiag v2.1

Metric	Result	Target	Assessment
Overall Accuracy	94.2%	> 95.0%	BELOW TARGET/ model improvement required
Sensitivity (True Positive Rate)	96.9%	> 98.0%	BELOW TARGET/ misses 3.1% of actual cancer cases
Specifically (True Negative Rate)	91.4%	> 90.0%	MEETS TARGET/ acceptable false positive
Accuracy White Patients	96.3%	> 95.0%	MEETS TARGET

Accuracy Black Patients	89.1%	> 95.0%	FAILS TARGET/ 7.2% gap Deployment blocked
Accuracy of Hispanic Patients	91.8%	> 95.0%	BELOW TARGET / 3.2% gap Improvement required.
Model Confidence Calibration	0.87	> 0.90	BELOW TARGET/ AI is overconfident in some predictions
Interference Time per Scan	2.3 sec	< 5.0 sec	MEETS TARGET/ fast enough for clinical workflow

6.2 Bias Testing Methods Used

- Disaggregated accuracy testing by demographic group
- Disparate-impact statistical analysis
- Training data audit revealed underrepresentation of Black patients (8% vs. 13% US demographic)
- Fairness metrics: equalized odds, demographic parity, individual fairness
- Independent red-team auditing by external AI-ethics firm

6.3 Key Finding / Root Cause of Bias

ROOT CAUSE IDENTIFIED:

NexaDiag's training data comes primarily from northeastern academic hospitals with predominantly white patient populations. This resulted in inadequate representation of Black and Hispanic patients, producing accuracy disparities.

REMEDIATION REQUIRED: Collect and incorporate **50,000 additional CT scans from minority-serving institutions** before retraining and re-evaluation.

7. MANAGE / AI Risk Treatment Plan

The MANAGE Function identifies the risk on the map, measures it, and applies treatments to reduce it to an acceptable level. This section documents the specific actions that NexaHealth

will take to address each identified risk before NexaDiag can be approved for clinical deployment.

7.1 Risk Treatment Actions

Risk	Priority	Treatment Action	Owner	Deadline
Demographic bias/ black patients	CRITICAL	Collect 50,000 additional scans from minority serving hospitals; retrain the model; Reward before any deployment	Data Team	Q2 2025
The false negative rate is too high	CRITICAL	But just a classification threshold to increase sensitivity, except for slightly more false positives to catch more true cancers	ML Team	Q1 2025
Lack of explainability	HIGH	Grab cam plus plus plus visualization plus written explanation summary for every AI flag; radiologist trains on AI output interpretation	Product Team	Q1 2025
Model drift over time	HIGH	Monthly automated performance monitoring triggers restraint if accuracy drops 2% from baseline, and any demographic	ML Ops Team	Ongoing
Over-reliance by clinicians	HIGH	Mandatory 2-hour training for all radiologists users, AI outputs, label AI assistant, human review required for quarterly compliance checks	Clinical Team	Pre- deployment
Data poisonous attack	MEDIUM	If I'm in training, integrity checks, cryptographic hashing of all training samples, and access control on the model training pipeline	Security Team	Q1 2025
Adversary image attacks	MEDIUM	Deploy adversary detection layer test model against known adversary perturbations, rate-limit API access	Security Team	Q2 2025

7.2 Ongoing Monitoring Plan

- Monthly demographic bias testing
- Quarterly clinical-performance reviews
- Annual independent third-party AI audit

- AI-incident response procedures aligned with FDA SaMD rules
- Radiologists may flag disagreements; all are reviewed monthly
- Model versioning is retained for 7 years

7.3 Deployment Decision

DEPLOYMENT STATUS HOLD—CONDITIONAL APPROVAL PENDING

NexaDiag v.2 is not approved for clinical deployment at this time due to CRITICAL findings that are blocking deployment.

Demographic bias 7.2% accuracy gap for black patients exceeds the acceptable threshold of 2%

False negative rate 3.1%, miss rate exceeds the clinical safety threshold of 2.0%

Conditional approval NexaDiag v.2.2 will be approved for limited pilot deployment in 2 hospitals upon successful completion of bias remediation and re-audit showing all demographic groups meet 95% accuracy target, and the false negative rate is below 2.0%.